

Questions

1. (10 points) A user logging in to an application is redirected to the following URL:

<https://wahh-app.com/MyAccount.php?uid=1241126841>

How can you test whether the application is using the UID parameter to enforce access controls in an unsafe way?

By changing the value in the url and seeing if access controls remain in place, you can determine whether the program is using the uid argument in an unsafe manner. While logged in as different users, alter, delete, or substitute invalid values for the uid. An identifier-based access control vulnerability is indicated if the application loads data from other users or permits access without appropriate session validation.

- Change uid to another number to see if another user's account loads.
- Remove or blank out uid check if access is still granted.
- Log in as a different user and repeat test horizontal access control.
- Try invalid or random UIDs to observe error handling and behavior.

2. (20 points) Compare and contrast the common access control methods: MAC, DAC, RBAC, and ABAC.

Mandatory Access Control is extremely safe yet inflexible and challenging to modify since it enforces access based on system-defined security labels. Although it gives resource owners freedom, discretionary access control raises the possibility of unintentional over-permissions. Role-Based Access Control is effective and scalable for big environments since it assigns users to predetermined organizational roles. With the most flexibility and granularity, attribute-based access control makes judgments based on a variety of factors, including user identification, resource type, location, and time. ABAC is the most flexible and context aware, RBAC is the most manageable for businesses, MAC is the strictest, and DAC is the most adaptable.